

Arquitectura híbrida de inteligencia artificial como instrumento de soberanía del dato y de ciberseguridad: estudio de caso de un despliegue por capas

Jonathan González Fernández

(EA1HET)

16 de agosto de 2026

Nota del autor

Este trabajo analiza una arquitectura de inteligencia artificial efectivamente diseñada por el autor. Los datos de configuración operativa, credenciales, identificadores de servicio y direcciones internas se han omitido deliberadamente. Las afirmaciones sobre el sistema estudiado se marcan a lo largo del texto según su estatuto epistémico, evidencia documental, inferencia razonada o cuestión no determinada, conforme a la convención descrita en la sección de metodología. El autor declara no tener conflicto de intereses con ninguno de los proveedores de software mencionados.

Tabla de contenidos

Abstract	4
Introducción	5
Marco conceptual.....	7
La soberanía del dato y sus tres dimensiones	7
Estado del marco jurídico en agosto de 2026	8
La arquitectura híbrida como categoría de diseño	10
Marcos de gestión de riesgo aplicables a sistemas de IA	11
Metodología de investigación	12
Diseño del estudio	12
Marco epistémico.....	13
Criterios de análisis.....	14
Descripción del caso: arquitectura híbrida por capas	14
Visión general	14
Capa de anticorrupción	15
Capa de gateway (pasarela) de IA	16
Capa de inferencia local.....	17
Capa de runtime de agentes de IA	18
Capa de servicios auxiliares.....	19
Análisis: la arquitectura como instrumento de soberanía	19
De la política al punto de control	19
El tráfico de datos salientes y la trazabilidad.....	20
Reversibilidad y mitigación de la dependencia del proveedor	21
Minimización de metadatos	22
Correspondencia entre capas y controles de soberanía.....	22
Análisis: superficie de ataque y controles de ciberseguridad	23
Premisa del análisis.....	23
Mapa de riesgos	24
Incertidumbres en el perímetro	25

Uso excesivo de agentes y MCP	26
El gateway de IA como punto único de fallo	27
Obligaciones NIS2	28
Aspectos no resueltos.....	29
Brecha de capacidad	29
El coste total de la autonomía tecnológica.....	29
Complejidad como superficie de exposición	30
La soberanía del dato como propiedad gradual	30
Limitaciones del estudio	30
Conclusiones	31

Abstract

Este artículo examina, mediante un estudio de caso instrumental, el despliegue de una arquitectura híbrida de inteligencia artificial (IA) en una organización, entendiendo por híbrida aquella que combina inferencia local sobre infraestructura propia con acceso controlado a modelos alojados por terceros. El objetivo es doble: describir cómo se materializa el principio de soberanía del dato en decisiones de arquitectura concretas y evaluar el perfil de riesgo de ciberseguridad que dicha arquitectura introduce, mitiga o desplaza.

El caso analizado organiza el sistema en cinco capas, anticorrupción, gateway de IA, inferencia local, runtime de agentes y servicios auxiliares, con una frontera explícita frente a Internet. El análisis se apoya en el modelo C4 para la descripción general, en el marco normativo europeo vigente en agosto de 2026 (Reglamento General de Protección de Datos, Reglamento de Inteligencia Artificial tras su modificación por el Ómnibus digital, Directiva NIS2, Reglamento de Datos y la propuesta de Cloud and AI Development Act) y en la taxonomía de riesgos OWASP Top 10 para aplicaciones basadas en modelos de lenguaje en su edición de 2026.

Los resultados sugieren que el valor principal de la hibridación no reside en eliminar la dependencia de proveedores externos, sino en convertirla en una decisión gobernada, reversible y auditable por dato y por caso de uso. Se identifican asimismo cuatro tensiones no resueltas: el coste de operación, la brecha de capacidad entre modelos locales y de frontera, la conversión del gateway de IA en punto único de fallo y la ampliación de la superficie de exposición asociada al runtime de ejecución de agentes. Se concluye con recomendaciones prácticas y con la delimitación explícita de las cuestiones que el caso no permite resolver

Keywords: *soberanía del dato, inteligencia artificial híbrida, ciberseguridad, gateway de IA, inferencia local, arquitectura por capas, agentes autónomos, cumplimiento normativo.*

Introducción

La adopción organizativa de la inteligencia artificial generativa en las organizaciones ha seguido, en su primera fase, un patrón de mínima fricción: contratar un servicio de terceros, integrarlo mediante una interfaz de programación de aplicaciones (API) y trasladar a ese proveedor la práctica totalidad del ciclo de vida del dato durante la inferencia. Ese patrón resolvió con rapidez el problema de la capacidad, pero desplazó tres decisiones que ninguna organización debería delegar por omisión: qué información sale de su perímetro, bajo qué jurisdicción queda sometida una vez fuera y con qué facilidad podría revertirse esa dependencia si las condiciones contractuales, técnicas, regulatorias o geopolíticas cambiaran.

El presente trabajo parte de la hipótesis de que esas tres decisiones no son en esencia jurídicas ni contractuales, sino de arquitectura. Una cláusula que prohíbe el entrenamiento con datos del cliente es una decisión verificable solo a posteriori y solo parcialmente; un diseño que impide técnicamente que determinadas categorías de dato abandonen la red interna es una restricción verificable a priori y de forma continua. La diferencia entre ambas no es de grado, sino de naturaleza: la primera pertenece al dominio de la confianza, la segunda al de la garantía.

Se denomina aquí *arquitectura híbrida de IA* a aquella que mantiene capacidad de inferencia sobre infraestructura controlada por la propia organización y, simultáneamente, conserva acceso gobernado a modelos alojados por terceros, de modo que la elección entre uno y otro no la toma el usuario en el momento del uso, sino la arquitectura en función de políticas previamente definidas. El adjetivo «híbrida» no describe, por tanto, una mezcla accidental de recursos, sino un mecanismo deliberado de asignación.

El objetivo general de este artículo es analizar, sobre un caso real, cómo se traducen los principios de soberanía del dato y de ciberseguridad en decisiones de diseño verificables. De él se

derivan cuatro objetivos específicos: (a) describir la arquitectura estudiada con un nivel de detalle suficiente para su replicación conceptual; (b) identificar qué controles de soberanía emergen de su estructura por capas; (c) mapear su superficie de ataque sobre una taxonomía de riesgos reconocida; y (d) explicitar las tensiones y contrapartidas que el diseño no resuelve.

Las preguntas de investigación que guían el trabajo son las siguientes. ¿Qué propiedades de soberanía se obtienen de la separación en capas y cuáles requieren controles adicionales de naturaleza organizativa? ¿En qué medida la introducción de un Gateway de IA y de un runtime de agentes reduce el riesgo añadido y en qué medida lo desplaza hacia componentes nuevos? ¿Qué obligaciones del marco normativo europeo vigente en agosto de 2026 encuentran soporte directo en esta arquitectura y cuáles quedan fuera de su alcance?

La relevancia del problema no es meramente teórica. La cuestión de si un proveedor sometido a la jurisdicción estadounidense puede garantizar que los datos de clientes europeos no serán entregados a autoridades de aquel país fue formulada de manera directa en junio de 2025 ante una comisión de investigación del senado francés, y la respuesta del representante legal de la filial francesa de un gran proveedor fue negativa: no podía garantizarlo, si bien afirmó que tal situación no se había producido (Sénat, 2025). Esa respuesta, ofrecida bajo juramento, condensa el argumento central de este artículo mejor que cualquier construcción académica: la localización física del dato en territorio europeo es condición necesaria pero no suficiente de la soberanía, porque lo determinante no es dónde reside la información, sino quién puede ser legalmente compelido a entregarla.

El artículo se organiza como sigue: la sección de marco conceptual delimita las nociones de soberanía del dato y de arquitectura híbrida y resume el marco normativo aplicable; la sección de método describe el diseño del estudio de caso y la convención de marcado epistémico empleada;

a continuación se describe la arquitectura estudiada, se analizan sus propiedades de soberanía y su perfil de ciberseguridad, y se discuten las tensiones no resueltas; el trabajo cierra con conclusiones, limitaciones y líneas de trabajo futuro.

Marco conceptual

La soberanía del dato y sus tres dimensiones

La expresión “*soberanía del dato*” se emplea con frecuencia como sinónimo de localización geográfica del almacenamiento, lo que empobrece considerablemente el concepto. Resulta más útil descomponerla en tres dimensiones analíticamente distintas y solo parcialmente correlacionadas.

La primera es la ***dimensión jurídica***: qué ordenamiento puede exigir el acceso a la información, con independencia del lugar en que esta se almacene. La Clarifying Lawful Overseas Use of Data (CLOUD) Act de 2018, codificada en el título 18 del Código de los Estados Unidos, sección 2713, obliga a los proveedores sometidos a la jurisdicción estadounidense a preservar y entregar los datos que estén bajo su posesión, custodia o control, con independencia de la ubicación física de los servidores (CLOUD Act, 2018). El corolario es tanto incómodo como inevitable: una región de un centro de datos situada en Fráncfort o en Madrid, operada por una sociedad matriz estadounidense, queda subyugada a esta ley.

La segunda es la ***dimensión operativa***: quién administra efectivamente el sistema, quién posee las credenciales privilegiadas y quién puede modificar la configuración sin intervención de la organización. Un servicio gestionado por un tercero desplaza esta dimensión aun cuando la infraestructura sea nominalmente propia.

La tercera es la ***dimensión técnica respecto de reversibilidad***: con qué coste y en qué plazo podría la organización sustituir al proveedor sin pérdida funcional. Esta dimensión es la que el legislador europeo ha abordado de forma más directa mediante el Reglamento (UE) 2023/2854, conocido como Reglamento de Datos, aplicable con carácter general desde el 12 de septiembre de 2025, cuyos artículos sobre cambio de proveedor de servicios de tratamiento de datos imponen obligaciones de portabilidad funcional, interoperabilidad y supresión progresiva de los gastos de cambio, que dejarán de poder repercutirse a partir del 12 de enero de 2027 (Parlamento Europeo y Consejo de la Unión Europea, 2023).

Estado del marco jurídico en agosto de 2026

El régimen de transferencias internacionales de datos personales continúa articulándose sobre el capítulo V del Reglamento General de Protección de Datos (Parlamento Europeo y Consejo de la Unión Europea, 2016), cuya interpretación quedó marcada por la anulación del Escudo de Privacidad en el asunto *Schrems II* (Tribunal de Justicia de la Unión Europea, 2020). La decisión de adecuación del Marco de Privacidad de Datos UE-EE. UU., adoptada en 2023, fue impugnada directamente ante el Tribunal General, que desestimó el recurso el 3 de septiembre de 2025 en el asunto T-553/23 (Tribunal General de la Unión Europea, 2025). El recurso de casación ante el Tribunal de Justicia se interpuso en octubre de 2025 y continuaba pendiente en la fecha de redacción de este artículo.

La consecuencia práctica, para el arquitecto de sistemas, es que el marco de transferencias es válido, pero conceptualmente inestable: dos regímenes previos fueron anulados por el mismo tribunal que ahora conoce del recurso. Diseñar sistemas bajo el supuesto de permanencia indefinida de la decisión de adecuación es, en términos de gestión de riesgos, una apuesta

demasiado arriesgada. La arquitectura híbrida puede entenderse precisamente como la materialización técnica una contramedida necesaria: si la vía de transferencia se cerrase o se restringiese, la organización conservaría capacidad operativa degradada pero funcional.

A esta capa se superponen tres marcos adicionales. El Reglamento (UE) 2024/1689, o Reglamento de Inteligencia Artificial, fue modificado por el Reglamento (UE) 2026/1744, denominado Ómnibus digital sobre inteligencia artificial, en vigor desde el 27 de julio de 2026, que aplazó al 2 de diciembre de 2027 las obligaciones de los sistemas de alto riesgo del anexo III y a agosto de 2028 las relativas a la IA incorporada en productos regulados, manteniendo intactas las prácticas prohibidas del artículo 5, el deber de alfabetización en IA del artículo 4 y las obligaciones de transparencia del artículo 50, aplicables desde el 2 de agosto de 2026 (Parlamento Europeo y Consejo de la Unión Europea, 2026). El aplazamiento no altera el fondo del análisis aquí realizado: la trazabilidad, el registro de eventos, la gobernanza del dato y la supervisión humana son buenas prácticas de ingeniería con independencia de su exigibilidad inmediata por cualquier norma.

La Directiva (UE) 2022/2555, conocida como NIS2, establece obligaciones de gestión de riesgos, seguridad de la cadena de suministro y notificación escalonada de incidentes (alerta temprana en veinticuatro horas, notificación en setenta y dos horas e informe final en el plazo de un mes), así como responsabilidad expresa de los órganos de dirección (Parlamento Europeo y Consejo de la Unión Europea, 2022). En España, la transposición mediante la Ley de Coordinación y Gobernanza de la Ciberseguridad continuaba en tramitación parlamentaria en agosto de 2026, más de veintidós meses después del vencimiento del plazo fijado por la directiva. Este dato se ha verificado en la fecha de redacción y debe ser de nuevo verificado antes de cualquier uso citable posterior a la fecha de publicación final, dado su carácter cambiante.

Finalmente, la Comisión Europea presentó el 3 de junio de 2026 la propuesta de Cloud and AI Development Act, pieza central de su paquete de soberanía tecnológica, que introduce un marco único de evaluación con niveles graduados de garantía de soberanía en la nube vinculados a la elegibilidad para la contratación del sector público (Comisión Europea, 2026). Su relevancia para este trabajo es prospectiva: si el marco prospera, las decisiones de arquitectura descritas aquí dejarán de ser una preferencia técnica para convertirse, en determinados sectores, en un requisito de acceso al mercado.

Las tres dimensiones no se implican mutuamente. Una organización puede tener soberanía técnica sobre un sistema alojado en infraestructura de un tercero sometido a jurisdicción extranjera, o carecer de soberanía operativa sobre un servidor situado en su propio centro de proceso de datos si delega su administración. El diseño arquitectónico opera principalmente sobre las dimensiones primera y la tercera; la segunda depende de decisiones de gobierno y de contratación.

La arquitectura híbrida como categoría de diseño

La literatura de arquitectura de software ofrece dos conceptos previos que resultan directamente aplicables.

El primero es la *capa anticorrupción*, propuesta por Evans (2003) como mecanismo de traducción que impide que el modelo conceptual de un sistema externo contamine el modelo del dominio propio. Trasladado al ámbito que nos ocupa, la capa anticorrupción impide que las particularidades de un proveedor concreto de modelos (su formato de mensajes, su esquema de autenticación, su taxonomía de parámetros) penetren y se acoplen en las aplicaciones de la organización, lo que constituye la precondition técnica de la reversibilidad.

El segundo es el modelo C4 de documentación de arquitectura (Brown, s.f.), que estructura la descripción de un sistema en niveles sucesivos de contexto, contenedores, componentes y código. El caso analizado se documenta en el nivel de contenedores, que es el adecuado para razonar sobre fronteras de despliegue, protocolos y responsabilidades, sin descender a detalles de implementación que resultarían irrelevantes para el análisis de soberanía.

A ambos se añade el principio de confianza cero (zero trust), formalizado en la publicación especial 800-207 del Instituto Nacional de Estándares y Tecnología estadounidense (Rose et al., 2020), según el cual la ubicación en la red no confiere confianza y toda solicitud debe autenticarse y autorizarse individualmente. La aplicación de este principio a los sistemas de IA es menos evidente de lo que parece, porque el componente que solicita el acceso (un agente autónomo) puede haber sido inducido a hacerlo por un tercero mediante manipulación del contexto.

Marcos de gestión de riesgo aplicables a sistemas de IA

Tres instrumentos ofrecen taxonomías operativas. El Marco de Gestión de Riesgos de IA del NIST (2023) organiza la gobernanza en cuatro funciones (gobernar, cartografiar, medir y gestionar) y su perfil de IA generativa (NIST, 2024) descende a riesgos específicos de esta familia de sistemas. La norma ISO/IEC 42001:2023 establece los requisitos de un sistema de gestión de la inteligencia artificial certificable, complementando a la ISO/IEC 27001:2022 en materia de seguridad de la información (Organización Internacional de Normalización, 2022, 2023). El tercero, y el más directamente aplicable al análisis técnico de este caso, es el Top 10 de OWASP para aplicaciones basadas en modelos de lenguaje, cuya tercera edición se publicó el 4 de agosto de 2026 y cuya ordenación combinó por primera vez la votación de la comunidad con datos de incidentes reales (OWASP GenAI Security Project, 2026). La inyección de instrucciones se

mantuvo en primera posición por tercer año consecutivo y el uso excesivo de agentes ascendió del sexto al tercer puesto, un desplazamiento que refleja la generalización de los despliegues de agentes de IA con capacidad de invocar herramientas. La premisa que atraviesa la edición de 2026 es especialmente pertinente para el diseño de arquitecturas: el objetivo no es construir un modelo que no pueda ser engañado, sino un sistema en el que el engaño del modelo no tenga consecuencias relevantes. Esa es, en esencia, una tesis sobre arquitectura, no sobre modelos.

El riesgo de inyección indirecta de instrucciones (aquel en que la carga maliciosa se oculta en un documento, un correo o una página web que el modelo lee, sin que el usuario haya escrito nada) fue caracterizado sistemáticamente por Greshake et al. (2023) y constituye el vector que más directamente afecta a las arquitecturas que incorporan búsqueda web, extracción de contenido y agentes con herramientas, como es el caso estudiado. A ello se suma el riesgo de filtración de información sensible por memorización, documentado empíricamente por Carlini et al. (2021), que es una de las razones sustantivas por las que la separación entre datos que pueden abandonar el perímetro y datos que no deben hacerlo resulta desde un punto de vista de arquitectura imprescindibles.

Metodología de investigación

Diseño del estudio

Se emplea un diseño de estudio de caso único de carácter instrumental, en el sentido establecido por Yin (2018): el caso no se estudia por su interés intrínseco, sino como vehículo para examinar un fenómeno más general, la traducción de principios de soberanía y seguridad en decisiones arquitectónicas. La unidad de análisis es el sistema en su conjunto, no cada componente

aislado, dado que las propiedades objeto de estudio son emergentes de la composición y no atribuibles a las piezas individuales.

La fuente primaria de evidencia es el diagrama arquitectónico del sistema en notación C4 de nivel de contenedores, complementado con el conocimiento del diseño por parte del autor. Las fuentes secundarias son los textos normativos citados y la literatura técnica referenciada, consultados en agosto de 2026.

Marco epistémico

Un estudio de caso escrito por quien diseñó el caso incurre con facilidad en un sesgo de racionalización retrospectiva: presentar como intencional lo que fue circunstancial, y como propiedad garantizada lo que es solo probable. Para mitigarlo, se adopta una convención explícita de marcado que se aplica en las secciones descriptiva y analítica:

- **[D]** *Documentado*: la afirmación se sigue directamente de la evidencia de arquitectura disponible o de una fuente normativa o técnica citada.
- **[I]** *Inferido*: la afirmación es una deducción razonada del diseño, coherente con la evidencia, pero que la evidencia no establece por sí sola. Su solidez depende de supuestos que se enuncian junto a ella.
- **[ND]** *No determinado*: la cuestión es relevante para el análisis, pero la evidencia disponible no permite resolverla. Se enuncia como pregunta abierta en lugar de resolverse por conveniencia narrativa.

Esta convención no es habitual en la literatura académica del área, que tiende a homogeneizar el estatuto de todas sus afirmaciones. Se adopta aquí porque la distinción entre lo que un diseño garantiza y lo que meramente favorece es precisamente el objeto de disputa en los debates sobre

soberanía tecnológica, donde la confusión entre ambas categorías tiene consecuencias prácticas severas.

Criterios de análisis

El análisis de soberanía se estructura sobre las tres dimensiones definidas en el marco conceptual, examinando para cada una qué elemento de la arquitectura la soporta y qué controles complementarios de naturaleza no técnica resultan necesarios. El análisis de ciberseguridad se estructura sobre las categorías del Top 10 de OWASP en su edición de 2026, examinando para cada riesgo relevante su exposición en el caso, el control de arquitectura que lo atenúa y el riesgo residual. Se descartan las categorías que no encuentran superficie de exposición en el sistema estudiado, indicando el motivo.

Descripción del caso: arquitectura híbrida por capas

Visión general

El sistema estudiado se documenta en el nivel de contenedores del modelo C4 y se organiza en cinco zonas lógicas contenidas en un límite de sistema denominado *arquitectura interna híbrida de IA*, con una frontera explícita frente a un ecosistema externo. Las cinco zonas son: capa anticorrupción, capa del Gateway de IA, capa de inferencia local, capa de runtime de ejecución de agentes y capa de servicios auxiliares [D]. La Figura 1, a continuación, reproduce la vista completa de esta arquitectura.

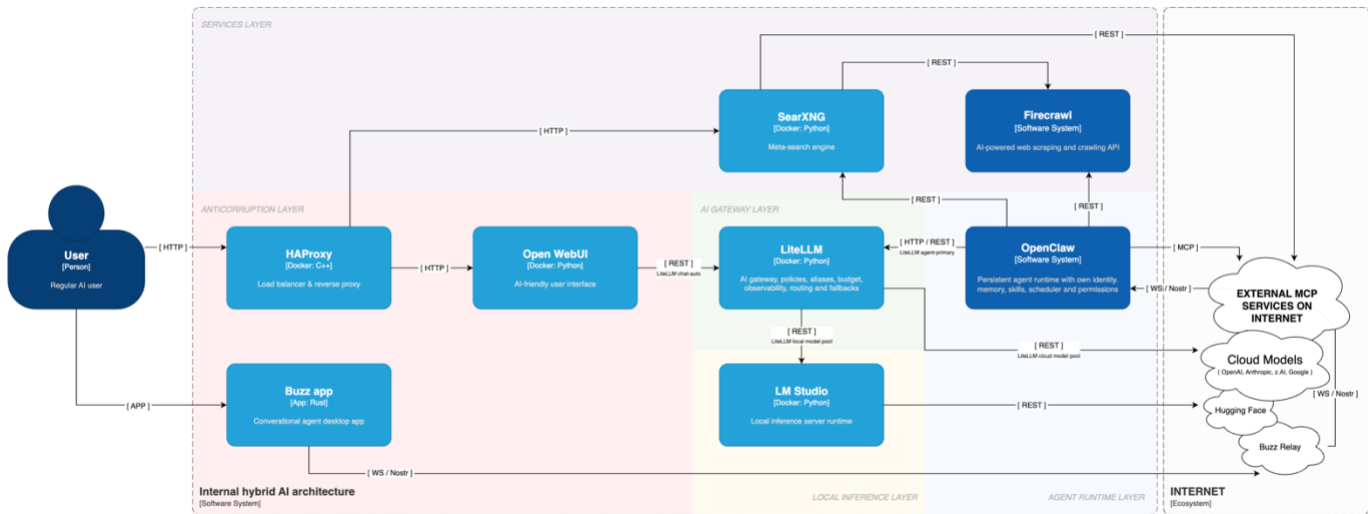


Figura 1: vista de contenedores (C4 nivel 2) de la arquitectura híbrida de IA analizada

Nota: figura de elaboración propia. Las etiquetas entre corchetes indican el protocolo de comunicación. Los recuadros discontinuos delimitan el sistema interno y el ecosistema de Internet. La versión original del diagrama admite ampliación; la reproducción a escala de página se ofrece aquí como referencia estructural, no como fuente de detalle.

La propiedad estructural más relevante del conjunto no es ninguna de sus piezas, sino la disciplina de tránsito que impone: ninguna aplicación de usuario invoca directamente un modelo, y ninguna petición de inferencia alcanza Internet sin atravesar un componente que puede registrarla, autorizarla o denegarla [D]. Esta propiedad es la que permite razonar sobre soberanía en términos de garantía y no de confianza.

Capa de anticorrupción

La capa anticorrupción agrupa los puntos de entrada del usuario y aísla el resto del sistema de las particularidades de las interfaces. La componen tres contenedores. HAProxy, desplegado en contenedor, actúa como balanceador de carga y proxy inverso, recibiendo el tráfico HTTP(S) del usuario y distribuyéndolo hacia la interfaz conversacional y hacia el motor de búsqueda interno

[D]. Open WebUI, en contenedor, proporciona la interfaz de usuario conversacional [D]. Buzz app, aplicación de escritorio, ofrece una vía de acceso alternativa de tipo agente conversacional [D].

La denominación de esta capa es deliberada y remite al patrón de Evans (2003). Su función no es meramente de enrutamiento: al concentrar la exposición al usuario, permite que las capas inferiores evolucionen (cambiando de modelo, de proveedor o de motor de inferencia) sin que ninguna aplicación cliente lo perciba [I]. El supuesto sobre el que descansa esta inferencia es que Open WebUI consume exclusivamente la interfaz normalizada de la pasarela y no interfaces específicas de proveedor, lo que resulta coherente con la etiqueta de la relación observada en el diagrama pero no queda demostrado por ella.

Buzz app introduce una asimetría que merece atención especial: además de operar como cliente local, mantiene una comunicación por WebSocket / protocolo Nostr con un retransmisor situado fuera del perímetro, denominado Buzz Relay, que a su vez conecta con el runtime de ejecución de agentes [D]. Es decir, existe un camino de comunicación entre un cliente de usuario y el agente interno que atraviesa infraestructura pública. Esta observación se retoma en el análisis de seguridad, porque constituye la excepción más significativa descrita en el apartado anterior.

Capa de gateway (pasarela) de IA

LiteLLM, en contenedor, concentra las funciones de gateway/pasarela: aplicación de políticas, gestión de alias de modelo, control de presupuestos, observabilidad, enrutado y mecanismos de control y actuación ante fallos [D]. Recibe peticiones REST desde Open WebUI bajo un perfil denominado *chat-auto* y desde el runtime de ejecución de agentes bajo un perfil denominado *agent-primary*, y las distribuye hacia dos conjuntos de destino: un conjunto de modelos locales y un conjunto de modelos en la nube [D].

Este componente es el núcleo funcional del carácter híbrido de la arquitectura. La existencia de dos conjuntos de destino diferenciados y de perfiles de consumo predefinidos indica que la asignación entre inferencia local y remota no se resuelve por defecto ni por preferencia del usuario, sino mediante configuración declarativa en un único punto [I]. El alcance de esa configuración (si se discrimina por sensibilidad del dato, por coste, por latencia, por capacidad requerida o por una combinación de estos factores) no puede determinarse a partir de la evidencia estructural disponible [ND]; se trata, no obstante, del parámetro que en mayor medida determina si la arquitectura entrega soberanía efectiva o meramente potencial.

La abstracción por alias merece una observación adicional. Cuando las aplicaciones invocan nombres lógicos de modelo en lugar de identificadores de proveedor, la sustitución de un proveedor por otro se convierte en una operación de configuración [I]. Esta es la traducción técnica precisa de la dimensión de reversibilidad definida en el marco conceptual, y el mecanismo por el que la arquitectura tiene en cuenta las obligaciones de portabilidad funcional del Reglamento de Datos (Parlamento Europeo y Consejo de la Unión Europea, 2023) sin depender de que el proveedor las cumpla por diligencia debida (due diligence).

Capa de inferencia local

LM Studio actúa como runtime de ejecución de servidor de inferencia local, recibiendo peticiones REST desde el gateway de IA y obteniendo modelos desde Hugging Face mediante REST [D]. Constituye la garantía material de que existe capacidad de inferencia que no depende de ningún tercero en tiempo de ejecución.

Conviene precisar el alcance de esa garantía: la independencia es de *ejecución*, no de *suministro*; los pesos de los modelos (los ficheros grandes a los que coloquialmente se les llama

“modelos offline”, resultado de vectorización y, eventualmente, de cuantización) proceden de un repositorio externo, de modo que la organización es soberana sobre el procesamiento, pero no sobre la producción de los artefactos que procesa [D], salvo que entrenase sus propios modelos. La mitigación evidente (replicar localmente los pesos verificados y desconectar la dependencia de descarga en tiempo de ejecución) es posible pero no puede afirmarse que esté implementada a partir de la evidencia disponible [ND].

Capa de runtime de agentes de IA

OpenClaw se describe como un runtime de ejecución de agentes persistente dotado de identidad propia, memoria, habilidades, planificador y permisos [D]. Sus relaciones son las más numerosas del sistema: consume la pasarela mediante HTTP y REST bajo el perfil *agent-primary*; invoca el motor de búsqueda interno y el servicio de extracción de contenido web mediante REST; se comunica con servicios MCP externos alojados en Internet mediante el Protocolo de Contexto de Modelo (MCP) y mantiene comunicación bidireccional por WebSocket / Nostr con el retransmisor externo [D].

Se trata, con diferencia, del componente con mayor concentración de riesgo del sistema, por una razón fundamental: es el único que combina persistencia de memoria entre sesiones, capacidad de invocar herramientas con efectos y lectura de contenido no confiable procedente de Internet. Cada una de estas tres propiedades es manejable por separado; su combinación define exactamente el perfil de amenaza que la edición de 2026 del Top 10 de OWASP sitúa en el centro de su análisis (OWASP GenAI Security Project, 2026).

La expresión “*identidad propia*” del componente admite dos lecturas que la evidencia no permite discriminar [ND]: puede significar que el agente opera bajo una identidad técnica

diferenciada a efectos de autenticación y autorización (lo que sería una decisión de diseño alineada con el principio de mínimo privilegio) o puede significar que posee un par de claves criptográficas para su participación en el protocolo Nostr. Ambas lecturas tienen implicaciones de seguridad distintas y no excluyentes.

Capa de servicios auxiliares

SearXNG, en contenedor, actúa como metabuscador que agrega resultados de motores externos y expone una interfaz interna, recibiendo tráfico HTTP desde el proxy inverso y peticiones REST desde el agente, y consultando Internet mediante REST [D]. Firecrawl proporciona capacidades de extracción y rastreo de contenido web asistido por IA, invocado por el agente mediante REST y accediendo a Internet por el mismo protocolo [D]. El diagrama sugiere además una relación REST entre el metabuscador y el servicio de extracción [I], cuyo sentido y propósito no quedan establecidos con claridad [ND].

La presencia interna de un metabuscador tiene una función de soberanía que suele pasar desapercibida y que se analiza en la sección siguiente: desacopla la consulta de la persona o sistemas de consulta.

Análisis: la arquitectura como instrumento de soberanía

De la política al punto de control

Toda política de gobierno del dato enuncia restricciones del tipo “*la información clasificada como confidencial no se procesará mediante servicios de terceros*”. La cuestión relevante no es si la política existe, sino dónde reside su punto de aplicación. Si reside en la

formación del personal, la política es una expectativa de comportamiento. Si reside en la configuración de un Gateway por la que necesariamente transita toda petición de inferencia, la política es un control.

La arquitectura estudiada desplaza el punto de aplicación desde el usuario hacia la infraestructura [I]. Este desplazamiento es la contribución principal del diseño a la soberanía del dato y su valor no es marginal: elimina toda una clase de incidentes (la denominada *IA en la sombra*, en la que los empleados recurren por su cuenta a servicios públicos de IA con información corporativa) no mediante prohibición, sino proporcionando una alternativa interna que es al menos tan cómoda como la externa. La inferencia descansa aquí en un supuesto conductual explícito: que los usuarios prefieren la vía disponible y suficiente frente a la vía prohibida, supuesto razonable pero no garantizado por la arquitectura.

El tráfico de datos salientes y la trazabilidad

La concentración del tránsito hacia modelos externos en un único componente produce tres propiedades derivadas [I]. La primera es la *observabilidad completa del tráfico de datos salientes*: existe un lugar en el que puede saberse qué se envió, a qué proveedor, bajo qué identidad y en qué momento. La segunda es la *interrumpibilidad*: la desconexión de un proveedor es una operación de configuración, no una intervención en múltiples aplicaciones. La tercera es la *atribución*: la asociación entre consumo, coste y responsable es posible sin instrumentación adicional en cada cliente.

Estas tres propiedades tienen correspondencia normativa directa. La observabilidad del tráfico de datos salientes es la base material del registro de tratamientos y de la evaluación de transferencias internacionales exigidos por el capítulo V del Reglamento General de Protección de

Datos (Parlamento Europeo y Consejo de la Unión Europea, 2016). La interrumpibilidad es la condición práctica de capacidad de ejecución de un plan de contingencia ante la eventual anulación de una decisión de adecuación, escenario aun abierto debido al estado legal del recurso contra el Marco de Privacidad de Datos mantiene abierto (Tribunal General de la Unión Europea, 2025). La atribución es un requisito operativo tanto del control presupuestario como de la trazabilidad que el Reglamento de Inteligencia Artificial exige a los sistemas sujetos a obligaciones reforzadas (Parlamento Europeo y Consejo de la Unión Europea, 2024, 2026).

Debe subrayarse, no obstante, que estas propiedades son *potenciales*: la arquitectura crea el lugar donde el control puede ejercerse, pero no determina que se ejerza. Un punto único de control de tráfico de datos salientes sin retención de registros, sin revisión periódica y sin alertas configuradas es, funcionalmente, un punto único de fallo y descontrol [D].

Reversibilidad y mitigación de la dependencia del proveedor

La dependencia de proveedor en sistemas de IA presenta una particularidad respecto de otras formas de dependencia tecnológica: no se manifiesta principalmente en el formato de los datos (los mensajes son texto estructurado y su traducción entre proveedores es trivial) sino en el *ajuste de comportamiento*. Las instrucciones de sistema, los umbrales, las estrategias de recuperación de información y los flujos de trabajo de agentes se afinan empíricamente contra un modelo concreto, y ese ajuste no es portable de manera automática.

La arquitectura por alias mitiga la primera forma de dependencia y no la segunda [I]. Sustituir un proveedor es, en este diseño, una operación de minutos en términos de conectividad; volver a alcanzar la calidad previa puede requerir semanas de reajuste. Reconocer esta asimetría es importante porque el discurso comercial en torno a los gateways de IA tiende a presentar la

reversibilidad como resuelta cuando solo está parcialmente abordada. La mitigación disponible (mantener el conjunto de modelos locales en uso real y no meramente como respaldo declarado, de modo que el ajuste se valide continuamente contra ambos destinos) es una decisión operativa, no de arquitectura.

Minimización de metadatos

El metabuscador local cumple una función de soberanía que no es evidente a primera vista. En una integración directa contra un motor de búsqueda comercial, cada consulta formulada por el sistema (incluidas las consultas derivadas de contenido interno confidencial) queda asociada al identificador del cliente corporativo. Al interponer un metabuscador propio, se rompe esa asociación: el motor externo recibe la consulta, pero no la identidad de quien la formula ni el contexto en que se genera [1].

La distinción es importante: el contenido de una consulta puede ser inocuo mientras que el patrón agregado de consultas de una organización a lo largo del tiempo constituye información competitivamente sensible; revela líneas de investigación, procesos de adquisición, incidentes en curso y prioridades estratégicas. La minimización de metadatos es, en este sentido, una dimensión de la soberanía del dato distinta de la protección del contenido y frecuentemente peor atendida.

Correspondencia entre capas y controles de soberanía

La Tabla 1 sintetiza la correspondencia entre cada capa de la arquitectura, la dimensión de soberanía sobre la que opera y el control complementario (no solo de arquitectura) que resulta necesario para que la propiedad se materialice.

Capa	Dimensión de soberanía	Propiedad que aporta	Control complementario necesario
Anticorrupción	Técnica (reversibilidad)	Aísla a los clientes de la interfaz del proveedor	Prohibición explícita de integraciones directas cliente-proveedor
Gateway de IA	Legal y técnica	Punto único de decisión y registro del tráfico de datos salientes	Política de clasificación del dato y revisión periódica de registros
Inferencia local	Legal y operativa	Capacidad de proceso sin dependencia de terceros en ejecución	Réplica interna de pesos (modelos) verificados/curados; plan de capacidad
Runtime de ejecución de agentes	Operativa	Identidad y permisos diferenciados por agente	Mínimo privilegio efectivo y aprobación humana de acciones
Servicios auxiliares	Legal (metadatos)	Desacopla la consulta de la identidad del cliente	Revisión de los motores externos agregados y de su retención

Tabla 1 Correspondencia entre capas de la arquitectura, dimensiones de soberanía y controles complementarios

Nota: *tabla de elaboración propia. La columna de propiedades recoge capacidades potenciales de la arquitectura; la última columna enumera las condiciones sin las cuales dichas capacidades no se materializan en control efectivo.*

Análisis: superficie de ataque y controles de ciberseguridad

Premisa del análisis

La edición de 2026 del Top 10 de OWASP para aplicaciones basadas en modelos de lenguaje introduce un desplazamiento conceptual que conviene adoptar como premisa: el objetivo del diseño no es impedir que el modelo sea engañado, sino acotar las consecuencias de que lo sea (OWASP GenAI Security Project, 2026). La razón es de orden técnico y no de resignación: en un modelo de lenguaje, la instrucción de sistema, la pregunta del usuario, el documento recuperado y la respuesta de una herramienta llegan como la misma secuencia de unidades léxicas, sin ninguna marca estructural que distinga cuáles están autorizadas a impartir órdenes. No existe, para la

inyección de instrucciones, un equivalente a la parametrización de consultas que resolvió la inyección SQL.

Aceptada esta premisa, el criterio de evaluación de una arquitectura deja de ser la robustez de los filtros y pasa a ser el radio de daño (blast radius) de un compromiso: qué puede alcanzar, leer, modificar o exfiltrar un componente que ha sido inducido a actuar en contra del interés de la organización.

Mapa de riesgos

La Tabla 2 recoge las categorías de riesgo con superficie de exposición identificable en el sistema estudiado, el control que la arquitectura aporta y el riesgo residual. Se ha verificado la posición en el listado de 2026 de las categorías de inyección de instrucciones, divulgación de información sensible, agencia excesiva, desinformación y manejo inadecuado de la salida; para las restantes se emplea la denominación sin afirmar su ordinal exacto en dicha edición [ND].

Categoría de riesgo	Superficie de exposición	Control de arquitectura	Riesgo residual
Inyección de instrucciones	Contenido web recuperado por el extractor y el metabuscador; mensajes recibidos por el retransmisor externo	Aislamiento de los servicios de recuperación en su propia capa	Alto: la lectura de contenido no confiable es funcionalmente necesaria
Divulgación de información sensible	Peticiones enrutadas al conjunto de modelos en la nube	Enrutado por política en el gateway; conjunto local alternativo	Medio: depende de la calidad de la clasificación previa del dato
Uso masivo de agentes	Agente con memoria persistente, planificador y herramientas MCP externas	Modelo de permisos e identidad propia del runtime de ejecución	Alto: crece con cada herramienta añadida
Cadena de suministro	Descarga de pesos/modelos desde repositorio externo; servidores MCP de terceros	Frontera explícita frente a Internet en el diagrama	Alto: no se evidencia verificación de artefactos ni fijación de versiones

Categoría de riesgo	Superficie de exposición	Control de arquitectura	Riesgo residual
Envenenamiento de datos y modelos	Pesos/modelos de origen externo; memoria del agente alimentada por contenido recuperado	Separación entre inferencia local y remota	Medio: la memoria persistente es el vector menos vigilado
Exposición de contexto oculto	Instrucciones de sistema y perfiles en el gateway	Centralización de la configuración	Medio: la centralización concentra el impacto de una filtración
Consumo no acotado	Rastreo web y bucles de planificación del agente	Control presupuestario y de gastos en la pasarela	Bajo para coste externo; medio para recursos locales
Desinformación	Respuestas sintetizadas a partir de fuentes web agregadas	Trazabilidad del origen de la información recuperada	Medio: mitigable con atribución de fuentes en la salida
Manejo inadecuado de la salida	Consumo de respuestas por clientes y por el agente	Interfaz normalizada del gateway	Medio: crítico si la salida alimenta ejecución de código

Tabla 2: Exposición de la arquitectura propuesta a las categorías de riesgo de OWASP para aplicaciones basadas en modelos de lenguaje largos

Nota: tabla de elaboración propia a partir de OWASP GenAI Security Project (2026). La valoración del riesgo residual es cualitativa y refleja el juicio del autor sobre el diseño documentado, no el resultado de una evaluación de seguridad ejecutada sobre el sistema en producción.

Incertidumbres en el perímetro

La observación más significativa del análisis de seguridad es que es difícil encontrar un modelo de funcionamiento que no tenga un o más excepciones: en este caso es la comunicación entre la aplicación de escritorio Buzz y el runtime de ejecución de agentes que atraviesa un relay Norespt situado fuera del perímetro [D]. Esto significa que existe un camino por el que instrucciones originadas fuera de la red interna alcanzan un componente dotado de memoria persistente y capacidad de invocar herramientas, sin pasar por el proxy inverso ni por el gateway.

La situación se genera a partir del diseño propuesto de forma premeditada para hacerse eco de las implementaciones propuestas por los desarrolladores de IA y de Agentes de IA. Las

implicaciones dependen de propiedades que la evidencia estructural no establece [ND]. Si la comunicación emplea cifrado extremo a extremo, el retransmisor no accede al contenido, pero sí observa metadatos: existencia de la conversación, momento, frecuencia, tamaño y claves públicas de los participantes. Si además el tiempo de ejecución acepta mensajes de cualquier remitente que conozca su clave pública, la superficie de ataque se extiende a cualquier actor de la red pública. La cuestión de qué política de autorización aplica el agente a los mensajes recibidos por esta vía es, a juicio del autor, la más relevante que el diseño documentado deja abierta.

La observación no invalida la decisión de diseño, que probablemente responde a un requisito legítimo de acceso remoto sin exponer servicios internos a Internet [I] (una elección de arquitectura preferible a abrir un puerto entrante). Lo que sostiene el análisis es que el beneficio de esta clase de implementaciones, opaca en esencia, degrada la solución final exactamente en la medida en que existan excepciones no equivalentemente controladas, y que dichas excepciones deben documentarse como tales y no quedar implícitas en el diagrama de arquitectura.

Uso excesivo de agentes y MCP

El uso excesivo (y en ascenso) de agentes de IA, del sexto al tercer puesto en la edición de 2026, responde a la generalización de despliegues como el analizado (OWASP GenAI Security Project, 2026). El protocolo MCP, introducido como estándar abierto para conectar sistemas de IA con fuentes de datos y herramientas (Anthropic, 2024), resuelve un problema real de integración y, al hacerlo, reduce drásticamente el coste marginal de conceder una capacidad nueva al agente. Ese es simultáneamente su mérito y su riesgo: cuando añadir una herramienta cuesta una línea de configuración, la superficie de autorización crece más deprisa que la reflexión sobre ella.

La combinación crítica se produce cuando concurren tres condiciones: el agente lee contenido no confiable, dispone de herramientas con efectos externos y opera sin aprobación humana intermedia. En el caso estudiado, las dos primeras condiciones se verifican documentalmente [D]; la tercera no puede determinarse [ND]. El control recomendado por la literatura es la separación estricta entre el privilegio de lectura y el privilegio de acción, de modo que ninguna cadena de razonamiento iniciada por contenido externo pueda desembocar en una acción con efectos sin mediación (Greshake et al., 2023; Rose et al., 2020).

Una segunda derivada, menos discutida, afecta a la memoria persistente. Un contenido malicioso incorporado a la memoria del agente no compromete una sesión, sino todas las posteriores, y lo hace de forma que ningún registro de la conversación en curso permite detectar. La memoria persistente convierte un incidente puntual en una condición latente, y su tratamiento requiere controles específicos (procedencia de cada elemento almacenado, caducidad, y capacidad de revisión y expurgo) que no forman parte del repertorio de acciones habituales de la seguridad de aplicaciones.

El gateway de IA como punto único de fallo

La concentración que otorga a la pasarela su valor de control le confiere simétricamente un perfil de criticidad extremo. Tres consideraciones se derivan de ello [I]. En primer lugar, su indisponibilidad interrumpe toda capacidad de inferencia del sistema, tanto local como remota, lo que exige tratarla con los requisitos de disponibilidad de un servicio esencial y no de un componente de integración. En segundo lugar, custodia las credenciales de todos los proveedores externos, por lo que su comprometer este sistema equivale a comprometer de forma simultánea todas las cuentas de proveedor de la organización. En tercer lugar, sus registros contienen, por

construcción, el contenido íntegro de las peticiones de inferencia: el sistema diseñado para observar el tráfico saliente de información sensible es, de facto, el mayor repositorio de información sensible del conjunto.

Esta última consideración tiene consecuencias directas de protección de datos que se pasan por alto con frecuencia. La política de retención de los registros de la pasarela, su cifrado en reposo, el control de acceso a ellos y su inclusión en el registro de actividades de tratamiento no son cuestiones de higiene operativa, sino requisitos derivados de los artículos 5, 25 y 32 del Reglamento General de Protección de Datos (Parlamento Europeo y Consejo de la Unión Europea, 2016).

Obligaciones NIS2

Para las entidades comprendidas en el ámbito de la Directiva NIS2, la arquitectura analizada aporta soporte material a varias obligaciones de gestión de riesgos: el registro centralizado del tráfico de datos salientes facilita la detección y el análisis de incidentes; la separación por capas soporta la segmentación exigible; y la existencia de capacidad local de inferencia constituye una medida de continuidad frente a la indisponibilidad de un proveedor externo (Parlamento Europeo y Consejo de la Unión Europea, 2022).

La obligación que la arquitectura no resuelve por sí misma es la de seguridad de la cadena de suministro. Un despliegue que integra contenedores de código abierto, pesos/modelos descargados de un repositorio público sin proceso de curación y servidores MCP operados por terceros presenta una cadena de suministro extensa y heterogénea, cuya gestión requiere inventario de componentes, fijación de versiones, verificación de integridad y evaluación de proveedores. Nada de ello es visible en la evidencia estructural analizada [ND], lo que no significa que no exista,

sino que no forma parte de lo que el diagrama documenta, una omisión por cierto, común en la documentación de arquitectura y que convendría corregir mediante una vista específica de cadena de suministro.

Aspectos no resueltos

Brecha de capacidad

La hibridación presupone que la alternativa local es suficiente para los casos de uso que se le asignan. Esta presuposición debe verificarse empíricamente y no darse por supuesta: si el conjunto local resulta insuficiente para las tareas que la política le atribuye, la presión operativa desplazará esas tareas hacia el conjunto remoto, y la arquitectura habrá producido documentación de soberanía en lugar de soberanía. El indicador de salud del diseño no es la existencia del conjunto local, sino su cuota real de uso sostenida en el tiempo.

El coste total de la autonomía tecnológica

El coste de una arquitectura híbrida no se agota en el material informático. Comprende la operación de siete u ocho servicios adicionales, su actualización, su supervisión y el conocimiento especializado necesario para sostenerlos. Para organizaciones sin capacidad interna de ejecución de plataformas informáticas, ese coste puede superar el valor de la soberanía obtenida, y una arquitectura correcta operada deficientemente es menos segura que una arquitectura sencilla bien operada. La recomendación derivable no es universal: la hibridación se justifica en organizaciones que tratan categorías de dato cuya salida del perímetro es inaceptable, o que están sujetas a requisitos sectoriales de regulación, de continuidad y localización.

Complejidad como superficie de exposición

Cada componente introducido para ganar control introduce a su vez su propia superficie de ataque, sus dependencias y sus vulnerabilidades. Existe, por tanto, un óptimo no trivial: por debajo de cierto umbral de componentes no hay control suficiente; por encima de otro, el sistema resulta ingobernable con los recursos disponibles. La determinación de ese óptimo para una organización concreta excede el alcance de este trabajo y constituye una línea de investigación en sí misma.

La soberanía del dato como propiedad gradual

La conclusión analítica más importante de la discusión es que la soberanía del dato no es un estado binario que se alcanza o no se alcanza, sino una propiedad graduable y por dominio. La arquitectura estudiada no elimina la dependencia de proveedores externos: la convierte en una decisión explícita, delimitada, observable y reversible. Esa transformación (de dependencia estructural a dependencia gobernada) es el resultado sustantivo del diseño, y es un resultado menor de lo que la retórica de la soberanía tecnológica suele prometer y mayor de lo que el escepticismo hacia ella suele conceder.

Limitaciones del estudio

Cuatro limitaciones acotan el alcance de las conclusiones. La primera es la naturaleza del caso único: las propiedades identificadas no son generalizables estadísticamente, sino analíticamente, en el sentido de que permiten refinar proposiciones teóricas y no estimar frecuencias poblacionales (Yin, 2018).

La segunda es la implicación del autor en el diseño del sistema analizado, que introduce un riesgo de sesgo de confirmación mitigado (pero no eliminado) por la convención de marcado epistémico adoptada.

La tercera es que el análisis se apoya en evidencia estructural y no en verificación empírica: no se han ejecutado pruebas de intrusión, revisión de configuración ni auditoría de registros. Las valoraciones de riesgo residual son, en consecuencia, hipótesis informadas y no hallazgos.

La cuarta es la volatilidad del marco normativo. Varias de las normas citadas se encuentran en tramitación, en fase de aplicación escalonada o pendientes de resolución judicial en la fecha de redacción. Cualquier uso posterior de este trabajo debe verificar el estado vigente de las fuentes jurídicas invocadas.

Conclusiones

El análisis del caso permite responder a las preguntas de investigación planteadas en los siguientes términos.

Respecto de las propiedades de soberanía obtenidas de la estructura por capas, se concluye que la arquitectura aporta tres controles de naturaleza verificable: un punto único de decisión y registro sobre la salida de información hacia terceros, una capacidad de proceso independiente de proveedores externos en tiempo de ejecución y una abstracción de proveedor que convierte la sustitución en una operación de configuración. Ninguno de los tres se materializa automáticamente: los tres requieren controles organizativos complementarios (clasificación del dato, revisión de registros, uso real y sostenido del conjunto local) sin los cuales la arquitectura produce capacidad potencial y no protección efectiva.

Respecto del desplazamiento del riesgo, se concluye que la arquitectura reduce el riesgo agregado de exposición de datos y de dependencia, y lo desplaza hacia tres concentraciones nuevas: el gateway de IA, que acumula credenciales, criticidad de disponibilidad y registros sensibles; el runtime de ejecución de agentes, que combina memoria persistente, herramientas con efectos y lectura de contenido no confiable; y el camino de comunicación externo por retransmisor, que constituye una excepción a la disciplina de tránsito general del sistema.

Respecto de la correspondencia normativa, se concluye que la arquitectura ofrece soporte material a obligaciones de trazabilidad, continuidad, segmentación y portabilidad derivadas del Reglamento General de Protección de Datos, del Reglamento de Datos, del Reglamento de Inteligencia Artificial en su versión modificada y de la Directiva NIS2, y que no ofrece soporte a las obligaciones de seguridad de la cadena de suministro, que requieren instrumentos de inventario y verificación ajenos al diseño analizado.

La contribución principal del trabajo, más allá del caso, es de orden conceptual: la soberanía del dato es una propiedad de arquitectura antes que legal. Las cláusulas describen comportamientos esperados de terceros; las arquitecturas determinan comportamientos posibles del sistema propio. Ante un marco jurídico cuya estabilidad ha sido cuestionada en dos ocasiones por el mismo tribunal que conoce del recurso pendiente, y ante una admisión pública de que la localización europea del almacenamiento no impide el acceso extraterritorial (Sénat, 2025), la diferencia entre ambos registros deja de ser una sutileza de ingeniería para convertirse en el criterio práctico de diseño.

Se proponen tres líneas de trabajo futuro: la validación empírica del mapeo de riesgos mediante pruebas adversarias sobre el sistema en producción; el desarrollo de métricas de soberanía efectiva (cuota real de inferencia local, tiempo medido de sustitución de proveedor,

cobertura de la clasificación del dato) que permitan superar la evaluación cualitativa; y el estudio comparado de varios casos que permita determinar el umbral de complejidad a partir del cual la solución de IA híbrida deja de ser rentable en términos de riesgos.

Bibliografía

- Anthropic. (2024, 25 de noviembre). *Introducing the Model Context Protocol*.
<https://www.anthropic.com/news/model-context-protocol>
- Brown, S. (s. f.). *The C4 model for visualising software architecture*. Recuperado el 16 de agosto de 2026, de <https://c4model.com>
- Carlini, N., Tramèr, F., Wallace, E., Jagielski, M., Herbert-Voss, A., Lee, K., Roberts, A., Brown, T., Song, D., Erlingsson, Ú., Oprea, A., & Raffel, C. (2021). Extracting training data from large language models. En *Proceedings of the 30th USENIX Security Symposium* (pp. 2633-2650). USENIX Association.
- Clarifying Lawful Overseas Use of Data Act [CLOUD Act], Pub. L. No. 115-141, div. V, 132 Stat. 348 (2018), codificada en 18 U.S.C. § 2713.
- Comisión Europea. (2026, 3 de junio). *Proposal for a Cloud and AI Development Act (CADA)*. Shaping Europe's Digital Future. <https://digital-strategy.ec.europa.eu/en/library/proposal-cloud-and-ai-development-act-cada>
- Evans, E. (2003). *Domain-driven design: Tackling complexity in the heart of software*. Addison-Wesley.
- Greshake, K., Abdelnabi, S., Mishra, S., Endres, C., Holz, T., & Fritz, M. (2023). Not what you've signed up for: Compromising real-world LLM-integrated applications with indirect prompt

- injection. En *Proceedings of the 16th ACM Workshop on Artificial Intelligence and Security* (pp. 79-90). Association for Computing Machinery.
- National Institute of Standards and Technology. (2023). *Artificial intelligence risk management framework (AI RMF 1.0)* (NIST AI 100-1). U.S. Department of Commerce. <https://doi.org/10.6028/NIST.AI.100-1>
- National Institute of Standards and Technology. (2024). *Artificial intelligence risk management framework: Generative artificial intelligence profile* (NIST AI 600-1). U.S. Department of Commerce. <https://doi.org/10.6028/NIST.AI.600-1>
- Organización Internacional de Normalización. (2022). *ISO/IEC 27001:2022. Information security, cybersecurity and privacy protection — Information security management systems — Requirements*.
- Organización Internacional de Normalización. (2023). *ISO/IEC 42001:2023. Information technology — Artificial intelligence — Management system*.
- OWASP GenAI Security Project. (2026). *OWASP top 10 for LLM applications 2026*. OWASP Foundation. <https://genai.owasp.org>
- Parlamento Europeo y Consejo de la Unión Europea. (2016). Reglamento (UE) 2016/679, de 27 de abril de 2016, relativo a la protección de las personas físicas en lo que respecta al tratamiento de datos personales y a la libre circulación de estos datos. *Diario Oficial de la Unión Europea*, L 119, 1-88.
- Parlamento Europeo y Consejo de la Unión Europea. (2022). Directiva (UE) 2022/2555, de 14 de diciembre de 2022, relativa a las medidas destinadas a garantizar un elevado nivel común de ciberseguridad en toda la Unión (Directiva NIS2). *Diario Oficial de la Unión Europea*, L 333, 80-152.

Parlamento Europeo y Consejo de la Unión Europea. (2023). Reglamento (UE) 2023/2854, de 13 de diciembre de 2023, sobre normas armonizadas para un acceso justo a los datos y su utilización (Reglamento de Datos). *Diario Oficial de la Unión Europea*.

Parlamento Europeo y Consejo de la Unión Europea. (2024). Reglamento (UE) 2024/1689, de 13 de junio de 2024, por el que se establecen normas armonizadas en materia de inteligencia artificial (Reglamento de Inteligencia Artificial). *Diario Oficial de la Unión Europea*.

Parlamento Europeo y Consejo de la Unión Europea. (2026). Reglamento (UE) 2026/1744, de 8 de julio de 2026, por el que se modifica el Reglamento (UE) 2024/1689 y otras normas conexas (Ómnibus digital sobre inteligencia artificial). *Diario Oficial de la Unión Europea*, publicado el 24 de julio de 2026.

Real Decreto 311/2022, de 3 de mayo, por el que se regula el Esquema Nacional de Seguridad. *Boletín Oficial del Estado*, 108, de 4 de mayo de 2022.

Rose, S., Borchert, O., Mitchell, S., & Connelly, S. (2020). *Zero trust architecture* (NIST Special Publication 800-207). National Institute of Standards and Technology. <https://doi.org/10.6028/NIST.SP.800-207>

Sénat. (2025, 10 de junio). *Audition de représentants de Microsoft France* [Commission d'enquête sur la commande publique et la souveraineté numérique]. République française. <https://www.senat.fr>

Tribunal de Justicia de la Unión Europea. (2020). *Data Protection Commissioner contra Facebook Ireland Ltd y Maximillian Schrems* (asunto C-311/18).

Tribunal General de la Unión Europea. (2025, 3 de septiembre). *Latombe contra Comisión Europea* (asunto T-553/23).

Yin, R. K. (2018). *Case study research and applications: Design and methods* (6.^a ed.). SAGE.